



תקציר מנהלי וטכני · מאומת מול קוד־המקור

מסמך חברה ומערכת

פלטפורמת אבטחה התקפית אוטונומית והגנה אקטיבית

קטגוריה

אבטחה התקפית אוטונומית + הגנה אקטיבית (Red-) Teaming אוטומטי מתמשך, ASM, מודיעין איומים, (SOAR, EDR/UEBA)

גרסה נוכחית

CalVer 2026.06.2 ("Liminal Boundary Engine")

היקף

כ-193,000 שורות קוד מקורי ב-Rust, React, SQL ו-Python

מוצר

Weissman Cybersecurity Platform

אופן אספקה

SaaS רב-דיירי + ניתן לאירוח עצמי; סוכן קצה חוצה-פלטפורמות (אופציונלי)

שפת ליבה

Rust (בטוחות-זיכרון; קוד unsafe אסור בכל הקרייט)

רישוי

קנייני (Proprietary)

תוכן עניינים

פרקים

1	תקציר מנהלים	14	הטעיה, בלימה וריפוי-עצמי
2	מה הפלטפורמה עושה	15	שכבת הנתונים: PostgreSQL, ריבוי-דיירים ומיגרציות
3	ארכיטקטורת המערכת	16	שרת ה-API, אימות, RBAC והקשחה
4	מערכת המנועים – הליבה הקניינית	17	תצפיתיות, זמינות גבוהה וגיבויים
5	שלמות הזיהוי ואינטליגנציית הממצאים	18	מרכז הפיקוד (ממשק הווב)
6	צינור מודיעין האיומים	19	פריסה ותשתית
7	מידול סיכון, נתיבי תקיפה ורדיוס נזק פיננסי	20	איכות הנדסית ושערי CI/CD
8	שכבת ה-AI האוטונומית	21	השכבה המסחרית: חיוב, קליטה וציות
9	תזמור ולולאת הפנטסט האוטונומית	22	עמדת בטיחות וממשל
10	סוכן הקצה ו-UEBA	23	מחסנית הטכנולוגיה
11	העובד האסינכרוני ומערכת המשימות	24	היקף הנדסי (במספרים)
12	אימות מחוץ-לתחום (OAST)	25	סטטוס כן והערות מפת-דרכים
13	SOAR, פלייבוקים והתראות		

נספחים

א'	נספח א' – קטלוג המנועים המלא (303 מנועים קבועים)	ג'	נספח ג' – מצאי נקודות-הקצה (API) המלא
ב'	נספח ב' – מצאי טבלאות מסד-הנתונים המלא (88 טבלאות)	ד'	נספח ד' – מצאי עמודי מרכז-הפיקוד המלא

תקציר מנהלים

1

Weissman Cybersecurity היא פלטפורמת אבטחה אוטונומית בלולאה-סגורה התוקפת באופן מתמשך את משטח-התקיפה של הארגון עצמו בדיוק כפי שיריב אמיתי היה עושה, מאמתת את ממצאיה בראיות חיות, מתמחרת את הסיכון העסקי בדולרים, ויכולה להגן, לבלום ולתקן באופן אוטומטי — הכל תחת ממשל בטיחות רב-שכבתי וקפדני.

זו אינה סורקת פגיעויות עם דאשבורד. זוהי מערכת משולבת המשלבת:

- **קטלוג עצום של מנועי אבטחה** — מעל 500 מזהי מנועים בקטלוג המוצר, הממופים לכ-300 מנועים קנוניים הממושים בנפרד, המשתרעים על Web, API, ענן, רשת, OT/ICS/IoT, זהות, שרשרת-אספקה, AI/LLM, קריפטוגרפיה, OSINT וזיהוי ברמת המארח. כל מנוע מחובר ל-probe אמיתי (HTTP, TCP, UDP, DNS, TLS); הקוד אוסר במפורש ממצאים מזויפים או אקראיים.
 - **“מועצת עליון” אוטונומית מבוססת-AI** — דיבייט יריב רב-מודלי (מציע התקפי, מבקר הגנתי “עיוור”, ומקבל-החלטות ריבוני) עם זיכרון מבוסס מסד-נתונים וקטורי של הצלחות עבר, שערי אישור אנושי בלולאה (HITL), ושובל ביקורת חתום קריפטוגרפית.
 - **שכבת שלמות-זיהוי** — זהות ממצא יציבה, deduplication, אשכול (clustering), לולאת משב false-positive עם שקלול ביטחון בייסיאני, ו-attestation קריפטוגרפי לכל ממצא.
 - **מודיעין איומים חי** — מראות מקומיות של CISA KEV ו-EPSS FIRST.org, המעשירות כל ממצא נושא-CVE בהסתברות-ניצול ובסטטוס “מנוצל-בפועל” ברגע שהוא נשמר.
 - **סיכון עסקי כמותי** — מודל מיושר-FAIR הממיר ממצאים טכניים לסכומי Single/Annualized Loss Expectancy בדולרים, בתוספת הסקת נתיבי-תקיפה מבוססת-גרף (Dijkstra מנכסים חשופי-אינטרנט אל “תכשיטי הכתר”).
 - **הגנה אקטיבית** — פלייבוקי SOAR, honeytokens/canaries, בענן, בלימת רשת, ויצירת טלאי תיקון אוטומטי המאומת ב-Docker שפותח Pull Requests.
 - **מישור-בקרה ארגוני** — API בן 130~ נקודות-קצה עם RBAC, SSO (OIDC/SAML), TOTP MFA + JWT בן שש דרגות, בידוד רב-דיירי ברמת-שורה ב-PostgreSQL, הגבלת-קצב לכל-דייר, ו"מרכז פיקוד" עשיר ב-React של כ-69 עמודים תפעוליים.
- המערכת בנויה ב-Rust לבטיחות-זיכרון וביצועים (כל בסיס-הקוד אוסר קוד **unsafe** למעט חריג יחיד ומתועד), מסופקת כקונטיינרים, ומגיעה עם תצפיתיות פרודקשן (Prometheus, OpenTelemetry), זמינות-גבוהה עם בחירת-מנהיג, וג'יבוים אוטומטיים.
- ההתחייבות הארכיטקטונית החשובה ביותר היא שלמות:** הממצאים מגיעים מ-probes אמיתיים, פלט ה-AI עובר אישור אנושי ומאומת מחוץ-לתחום לפני שהוא “נלמד”, וכל פעולה מורשית נרשמת ביומן. זה הופך את פלט הפלטפורמה לבר-הגנה — רף האיכות שמצופה מתוכנת-תשתית.

מה הפלטפורמה עושה

2

ברמה הגבוהה ביותר, הפלטפורמה מריצה לולאה אוטונומית ומתמשכת לכל לקוח:

1. **גילוי** משטח-התקיפה האמיתי של הלקוח (דומיינים, תת-דומיינים, כתובות IP, פורטים, נכסי ענן, ספקי SaaS/זהות, תלויות תוכנה) באמצעות OSINT וסריקה אקטיבית.
2. **תקיפה** של משטח זה באמצעות מאות מנועים מתמחים המדמים טכניקות יריב אמיתיות — בבטחה ובתוך תחום מאושר.

3. **אימות** כל בעיה אפשרית בראיות חיות, כולל קריאות-חזרה מחוץ-לתחום לפגיעויות "עיוורות" וארגזי-חול ארעיים ב-Docker להוכחת-ניצול.
 4. **העשרה ותיעדוף** כל ממצא עם מודיעין-ניצול חי (KEV/EPSS), ביצוע deduplication ואשכול, שקלול לפי דיוק היסטורי, ותמחור בדולרים של נזק עסקי.
 5. **הסקה** על התוצאות באמצעות מועצת AI רב-מודלית המציעה, מבקרת ומחליטה על שרשראות-תקיפה ותיקונים — תחת אישור אנושי היכן שזה חשוב.
 6. **הגנה ותיקון** אוטומטיים: הפעלת פלייבוקי SOAR, פריסת נכסי הטעיה, בלימת מארחים שנפרצו, ופתיחת Pull Requests מאומתים לתיקון.
 7. **דיווח** לכל קהל: מרכז-פיקוד תפעולי חי, מסמכי PDF מנהליים לדרג הדיקטוריון, ועמדת ציות מול SOC 2 / ISO 27001 / GDPR.
- לפיכך אותה פלטפורמה משרתת אנליסט SOC (תיעדוף וציד), מהנדס אבטחה (ממצאים מאומתים ותיקון אוטומטי), CISO (סיכון בדולרים ועמדת ציות), וכן MSSP/ספק-שירות (תפעול רב-דיירי על-פני ארגונים רבים).

ארכיטקטורת המערכת

3

הפלטפורמה היא **workspace** של Rust בן תשעה קרייטים, בתוספת frontend ב-React ושכבת כלי-Python מדור-קודם דקה.



קרייטים ב-Workspace (Rust):

תפקיד	קרייט
לב המערכת: 239~ מודולים — כל מנועי האבטחה, התזמור, מועצת ה-AI, השמירה, המודיעין, האימות ושכבת ניתוב ה-HTTP (~78K שורות <code>.rs</code> + ~18K שורות קבצי <code>handler .inc</code>).	<code>fingerprint_engine</code>
בינארי ה-HTTP בפרודקשן — בונה את ראوتر Axum, מיישם את מחסנית האבטחה (middleware), מנהל בריכות-DB, ומריץ שומרי-בטיחות באתחול.	<code>backend/weissman-server</code>
מודלים משותפים, רישום מזהי-המנועים הסמכותי, מדיניות TLS, הגדרות OpenAPI.	<code>backend/weissman-core</code>
trait מנועים ניתן-להרחבה (<code>CyberEngine</code>) ולקוח ה-LLM תואם OpenAI.	<code>backend/weissman-engines</code>
גישה למסד-נתונים, בריכות-חיבור, ומריץ-המיגרציות הדו-שלבי המותאם-אישית.	<code>crates/weissman-db</code>
צרכן המשימות האסינכרוני העצמאי.	<code>crates/weissman-worker</code>
סוכן הזיהוי + UEBA חוצה-הפלטפורמות בקצה (בינארי יחיד ~5MB).	<code>crates/weissman-agent</code>
מאזין אינטראקציות מחוץ-לתחום (DNS + HTTP) עצמאי לאימות פגיעויות עיוורות.	<code>crates/weissman-oast-server</code>
פרימיטיבים משותפים ל-fuzzing.	<code>fuzz_core</code>

מערכת המנועים — הליבה הקניינית

4

4.1 איך מנועים עובדים

כל הסריקה זורמת דרך מתזמר מרכזי יחיד (`engine_dispatch::run_engine`). העיצוב אוסף שלוש אינווריאנטות יוצאות-דופן לקטגוריית מוצר זו:

- נקודת-כניסה יחידה ומשוערת.** כל קריאת מנוע עוברת דרך פונקציה אחת המאמתת שהמנוע הוא מנוע-פרודקשן אמיתי, מנתבת מנועים הדורשים-סוכן אל סוכן-הקצה, ומתייגת כל ממצא במנוע-המקור שלו לצורך שרשרת-ראיות מלאה.
- פרימיטיבי `probe` אמיתיים ומשותפים.** מודול יחיד (`engine_probes.rs`) מספק את פרימיטיבי-הרשת היחידים שהמנועים רשאים להשתמש בהם: לקוחות HTTP/1.1 ו-HTTP/2, גולמי, probes ב-(A/TXT/MX/CAA) DNS, UDP, ופענוח תעודות TLS באמצעות OpenSSL. כותרת המודול מצהירה ישירות: *כל פונקציית-עזר מבצעת פעולות רשת חיות; אין ממצאים מדומים.*
- אין-אות פירושו אין-ממצא.** כשמנוע אינו צופה דבר, הוא מחזיר אפס ממצאים עם ההודעה "no live signal observed" — הוא אינו ממציא תוצאה.

המנועים רשומים ברשימה סמכותית (`PRODUCTION_ENGINE_IDS`) ב-`backend/weissman-core`, וסקריפט CI (`verify_engine_wiring.mjs`) **מכשיל את ה-build** אם מנוע כלשהו המוצג בממשק חסר נתיב-ביצוע אמיתי. כך המוצר שומר על כנות הקטלוג שלו.

4.2 הקטלוג (לפי תחום) ■

קטלוג המוצר חושף **מעל 500 מזהי מנועים** (רישום ה-frontend מונה ~529; רישום-הביצוע המסודר מגדיר ~303 מנועים קנוניים; השאר הם כינויים אנכיים/שיווקיים שמתמפים למימושים קנוניים). מבין המנועים הקנוניים, ~49 הם **דורשי-סוכן** (טכניקות ברמת-מארח שלא ניתן לצפות בהן מרחוק, ומסומנות ככאלה); השאר רצים מרחוק. תחומים מרכזיים:

תחום	מנועים מייצגים	מה הם עושים בפועל (מהקוד)
API-Web	BOLA/IDOR, GraphQL deep attack, JWT, OAuth/OIDC, XXE, SSTI, HTTP smuggling, cache, SAML, SSRF poisoning, prototype pollution, WebSocket, WAF bypass, CORS, subdomain takeover, Liminal Boundary (פרוטוקול HTTP/1 מול HTTP/2)	בדיקת HTTP חיה עם payloads, ניתוח כותרות/JSON, דיפרנציאלים בייסליין-מול-מוטציה, introspection ב-metadata-canaries עם GraphQL, SSRF
ענן	serverless, IaC, קונטיינר, AWS/Azure/GCP, Kubernetes misconfig, container registry, Cloud Hunter	SSRF לנקודות-מטא-דאטה, enumeration של S3/Azure/GCP, זיהוי השתלטות DNS תלוי, בדיקות חשיפת IAM/K8s
רשת	רשת-מתקדם (TCP/UDP אמיתי), SMB/NetBIOS, IPv6, mTLS/gRPC, BGP/DNS hijacking, timing	באגרי TCP, probes שירותי UDP, אימות-דואר, DNS (SPF/DMARC/CAA), timing ניתוח host-header rebinding ב-HTTP
OT / ICS / IoT	Modbus, BACnet, OPC-UA, MQTT, CoAP, SCADA, IoT firmware, BLE/RF	probes אמיתיים בפרוטוקולים תעשייתיים (למשל Modbus FC03 מעל TCP/502), טביעת-אצבע פורטים ובאגרים של IoT
זהות	Kerberoasting, password spray, מנוע-זהות, הסלמת-הרשאות אוטונומית	סריקת פורטי AD, anonymous LDAP, bind, replay של JWT/סשן רב-תפקידי, בדיקות HMAC
שרשרת-אספקה	מנוע שרשרת-אספקה, SBOM analyzer, ניטור, typosquatting, CI/CD	מושך את manifests/SBOMs של היעד עצמו, מנתח lockfiles, מבצע שאילתות OSV רק עבור גרסאות הקיימות בפועל ביעד
AI / LLM	מנועי AI מתקדמים, LLM red-team, adversarial ML, generative fuzzing	probes חיים של נקודות-קצה: LLM: jailbreak canaries, plugin manifests, DoS באמצעות מיצוי-טוקנים, prompt-injection
Recon / OSINT	OSINT, ASM, discovery/spider hunter, סריקת סודות ב-GitHub, passive DNS, leak	תת-דומיינים מ-Certificate Transparency (crt.sh), סריקות פורטים, crawling, ציד דליפות
קריפטוגרפיה	PKI/TLS, סורק-padding-oracle/RSA, post-quantum (PQC), timing	בדיקת תעודות TLS, עמדת מוכנות PQC, ערוצי-צד קריפטוגרפיים
Malware / התחמקות / הנדסה-חברתית	EDR evasion, anti-forensics, מנועי stealth, הנדסה-חברתית	היוריסטיקות מרחוק + בדיקות ברמת-מארח דרך הסוכן; אימות-דואר וגילוי OAuth (לעולם לא נשלחים payloads של פייסינג)
אמולציית APT	מנועי APT מתקדמים, אמולציית איומים (7 פרסונות שחקנים)	ממפה משטחי גישה-ראשונית מתועדים של שחקנים (Exchange OWA, Citrix, RDP/SMB חשופים) לראיות חיות; מסווג חסום מול לא-חסום

תחום	מנועים מייצגים	מה הם עושים בפועל (מהקוד)
Fuzzing	fuzzer מבוסס-משוב, OOB fuzz, semantic fuzzer, eternal fuzz	זיהוי אנומליות בייסליין-מול-מוטציה עם מוטציה מונחית-LLM אופציונלית ואישור מחוץ-לתחום

4.3 סינתזת ניצול ואימות

עבור דריסות-רגל מאומתות, **מנוע סינתזת הוכחת-הניצול (PoE)** (`exploit_synthesis_engine.rs`), המודול הבודד הגדול ביותר בכ-2,800 שורות) מריץ צינור ממושמע: טביעת-אצבע בייסליין → התאמת CVE מול NVD → עד 512 probes דינמיים מקבילים → טריגרים היוריסטיים (5xx, timeouts, אנטרופיה/דליפת-זיכרון, timing) → **PoC מסונתז ב-LLM עם מסילות-בטיחות** ותיקון-עצמי → **סולם-אימות** רב-שכבתי:

- **ארגז-חול ארעי ב-Docker** (`poc_sandbox.rs`) המריץ מחדש את ה-PoC מול היעד שבתחום, עם מגבלות משאבים נוקשות (256MB RAM, 0.5 CPU), ומסמן "מאומת" רק בקבלת קריאת-חזרה מחוץ-לתחום או סמן-תגובה צפוי;
 - **קורלציית קריאת-חזרה OAST** למחלקות עיוורות;
 - **שופט LLM סמנטי** עם סף-ביטחון מינימלי.
- ארגז-חול נפרד ל"***"אימות 200%*** (`verification_sandbox.rs`) מאמת תיקונים: הוא משכפל את ריפו-היעד, מקים **קונטיינר Docker מונע-Bollard**, מאשר שהניצול עובד לפני-הטלאי, מיישם את הטלאי המועמד, מאתחל מחדש, ומאשר שהניצול כבר אינו עובד — לפני שנפתח Pull Request כלשהו.

5 שלמות הזיהוי ואינטליגנציית הממצאים

5

שכבה זו היא מה שמבדיל פלטפורמה אמינה מסורק רועש. הכל ממומש בקוד:

- **זהות ממצא יציבה.** מזהה כל ממצא הוא hash של אינוריאנטות בלבד (מנוע, יעד, CVE, CWE, טכניקת MITRE, חתימה, כותרת מנורמלת) — תוך החרגה מפורשת של חותמות-זמן וגופי-תגובה — כך שאותה בעיה המזוהה-מחדש בסריקה הבאה היא אותה ממצא, לא כפילות.
- **deduplication אמיתי.** אילוץ `UNIQUE(tenant_id, client_id, finding_id)` עם `ON CONFLICT DO UPDATE` מרענן ראיות ומגדיל `seen_count` / `last_seen_at`, תוך **שימור הסטטוס שנקבע ע"י האנליסט** (`acknowledged` / `false-positive` / `fixed`) לאורך סריקות חוזרות.
- **אשכול.** ממצאים מאושכלים לפי `sha256(target || signature || cwe)` (עם נרמול URL), ומאחדים את המנועים, המקורות, ה-CVEs וחומרת CVSS/EPSS המקסימליים שתרמו.
- **לולאת משוב false-positive.** סימוני TP/FP של אנליסט מזינים **מכפיל-ביטחון** בשקלול בייסיאני (Bayesian shrinkage) = $\frac{(tp+1)}{(tp+fp+1)}$, מהודק לטווח `[0.1, 1.0]`, המוחל על ציון-הסיכון בזמן-קריאה. שלושה סימוני false-positive על אותו (מנוע, חתימה) **מדכאים אוטומטית** את הזיהוי הבא — תוך שימור שובל-הביקורת.
- **attestation קריפטוגרפי.** בזמן השמירה, כל ממצא מקבל קבלת HMAC-SHA256 על שדותיו הבלתי-משתנים, כך שניתן לזהות חבלה בממצאים שמורים בעת קריאה.
- **קורלציית kill-chain.** מעבר ל-dedup, מנוע חוקי-קורלציה מקבץ שלבי-ממצא מסודרים בתוך חלון-זמן לאירועים.
- **תיעודך ברירת-מחדל.** הממצאים ממוינים **ביטחון** `CVSS × EPSS → KEV` — כלומר, בעיות מנוצלות-בפועל ובעלות הסתברות-ניצול גבוהה צפות ראשונות, משוקללות בדיוק ההיסטורי של המנוע.

צינור מודיעין האיומים

6

הפלטפורמה מתחזקת מראות מקומיות חיות של מודיעין-ניצול סמכותי ומעשירה ממצאים אוטומטית:

הזנה	מקור	תדירות-רענון	אחסון
CISA KEV (פגיעויות מנוצלות-בפועל)	הזנת JSON רשמית של cisa.gov	כל 6 שעות	טבלת <code>kev_intel</code>
FIRST.org EPSS (ניקוד חיזוי-ניצול)	api.first.org	כל 12 שעות + לפי-דרישה בשמירה	טבלת <code>epss_intel</code>
NVD CVE	NIST NVD API 2.0	חיפוש-מילות-מפתח מטמון	מטמון LRU בזיכרון
OSV / GitHub Advisories	osv.dev, GitHub	מטמון, מאוגד (batched)	LRU + מילוי-לאחור

כל ממצא נושא-CVE מועשר בזמן השמירה ב- `epss_score`, `epss_percentile`, `kev_listed`, `kev_known_ransomware` ו- `kev_due_date`. מילוי-לאחור ברקע מפענח מזהי GHSA/OSV CVEs ומחשב מחדש את הדגלים הללו על-פני ממצאים קיימים. התוצאה: התיעודף משקף את מה שתוקפים מנצלים בפועל כעת, ולא רק CVSS סטטי.

מידול סיכון, נתיבי תקיפה ורדיוס נזק פיננסי

7

הפלטפורמה הופכת אלפי ממצאים למספר קטן של החלטות:

- גרף הסיכון.** גרף חי (`risk_graph_nodes` / `risk_graph_edges`) מודל נכסים, זהויות, רשתות, חבילות, ריפוזיטוריות, משאבי-ענן ואשכולות Kubernetes, עם קשתות כמו *exposes, authenticates, affects, leads_to*. הצמתים מנוקדים ונקודות-חנק (צמתים בעלי דרגה גבוהה ומגוון סוגי-קשת) מסומנות אוטומטית.
- הסקת נתיבי-תקיפה.** חיפוש Dijkstra למסלול הקצר ביותר רץ מכל צומת `internet_exposed` אל כל צומת `crown_jewel`, עם משקל-קשת הנגזרים מה- $KEV \times 2 + EPSS \times 1.5 + CVSS$ הגרועים ביותר של כל צומת. הוא מחזיר את K המסלולים המובילים (ברירת-מחדל 25, מקסימום 12 קפיצות) ואת נקודות-החנק המופיעות ב- $\geq 50\%$ מהם — כלומר, “תקן את הצומת הזה ותשבור את רוב נתיבי-התקיפה.” תצלומי-מצב נשמרים לניתוח-מגמות.
- רדיוס-נזק פיננסי (מיושר-FAIR).** הממצאים מתומחרים בדולרים:
 - תוחלת-הפסד בודד: $SLE = \text{ערך_נכס} \times \text{clamp}(CVSS/10, 0.5, 1.0)$
 - תוחלת-הפסד שנתי: $ALE = SLE \times \text{clamp}(EPSS \times 12, 0..12) \times \text{discount}$, כאשר CVEs ברשימת-KEV מציבים רצפה לקצב-ההתרחשויות השנתי על 1.0/שנה.
 - כללי תיוג ערך-נכס לכל-לקוח מאפשרים ללקוחות למפות תגיות-נכס משלהם לערכים בדולרים. הפלט מתגלגל ל-SLE הגרוע-ביותר, ALE שנתי, ערך תכשיט-הכתר, וסך ערך-הנכסים לכל לקוח.
- זיכרון חיזוק לפנטסט.** כל payload מנצח-ומאומת מוטמע כווקטור בן 1536 ממדים הממופתח לטביעת-אצבע היעד (שרת + מחסנית-טכנולוגיה) ונשמר עם אינדקס HNSW ב-pgvector. בסריקה הבאה מול מחסנית דומה, המערכת מאחזרת הצלחות-עבר באמצעות חיפוש שכן-קרום-בקירוב (ANN) — ועוקבת אחר שיעור-הצלחת-החזרה, כך שהלמידה-בחיזוק מדידה.

שכבת ה-AI האוטונומית

8

זוהי הקניין הרוחני המובחן ביותר של הפלטפורמה: **ארכיטקטורת-החלטות שכבתית** המשתמשת במספר מודלי-LLM באופן יריב, זוכרת מה עובד, ולעולם אינה ממיינת דבר לנשק ללא אימות ו(היכן שזה חשוב) אישור אנושי.

8.1 מועצת-העליון (דיבייט יריב רב-מודלי)

ממומשת ב- `council.rs` (~1,800 שורות), המועצה מעמתת מודלים שונים זה מול זה בתפקידים מוגדרים:

- **מציע התקפי** (למשל מודל ייעודי-קוד) המציע אסטרטגיות-תקיפה מובנות כ-JSON — לא פרוזה מנושקת;
- **מבקר הגנתי** שניווט במכוון ל-`payload` הקונקרטי ומבקר את סיכון-הזיהוי וסבירות ה-`false-positive`;
- **גנרל ריבוני** בעל סמכות סופית המסנתז `directive` בר-פעולה-מכונית.

המועצה היא **אגנוסטית-לספק** — היא דוברת את פרוטוקול-הצ'אט של OpenAI ורצה מול OpenAI, Ollama, vLLM, או כל `backend` תואם, עם בחירת-מודל לכל-דייר. כל שלב **חתום ב-HMAC/SHA-256 לתוך יומן-הביקורת** כאירוע `COUNCIL_DEBATE`. לולאת תיקון-עצמי מבוססת-OAST מריצה מחדש את הדיבייט (עד מספר סבבים מוגדר) כש-`probe` חי אינו מאשר את האסטרטגיה.

8.2 זיכרון RAG — לולאת-למידה סגורה

אסטרטגיות מנצחות מוטמעות ונשמרות ב- `supreme_council_memory` (pgvector, אינדקס קוסינוס HNSW). לפני כל דיבייט חדש, המערכת מאחזרת את K ההצלחות-הקודמות הדומות ביותר באמצעות חיפוש שכן-קרוב-בקירוב ומזריקה אותן לפרומפט של המציע. באופן מכריע, **הזיכרון נכתב רק לאחר ש-`probe` מחוץ-לתחום מאשר הצלחה** — הלולאה לומדת מתוצאות מאומתות, לא מטענות המודל. כשלי-הטמעה מתדרדרים בחן (אין וקטורים מזויפים).

8.3 "Ask Weissman" — משפה טבעית ל-SQL בטוח

עיצוב-בטיחות בולט (`nl_query.rs`): המשתמשים שואלים בשפה טבעית; ה-LLM פולט `QueryPlan` מובנה כ-JSON — לעולם לא SQL גולמי. השרת מאמת את התכנית מול `allow-list` (6 טבלאות, עמודות מנויות, 10 אופרטורים), מהדר אותה ל-SQL פרמטרי עם `tenant_id` שמוכרח לתוך כל שאילתה, ומריץ אותה מול **תפקיד PostgreSQL ייעודי לקריאה-בלבד** (`weissman_ro`) עם `timeout` של 15 שניות לפקודה. כל שאלה, ה-SQL המהודר, ספירת-השורות וההשהיה נרשמים ביומן. זה הופך ממשק-נתונים בשפה-טבעית לבטוח מספיק לפרודקשן.

8.4 סינתזת Genesis ו"מרתף החיסונים"

מועצה נפרדת ("Genesis") מאמתת שרשראות-תקיפה מראש: מציע בונה שרשרת, מבקר מגביל אותה, מודל-עקיפה בודק את ההגבלה, ואם השרשרת מתאמתת — מודל **"חיסון"** מפיק טלאי-תיקון וגם חתימת-זיהוי. שרשראות מאומתות הופכות לרשומות מוצפנות (AES-256-GCM) במרתף ומוזרמות בשידור חי ל"חדר-מלחמה" של המנכ"ל.

8.5 תת-מערכות "ריבוניות" אוטונומיות

משפחה של לולאות אוטונומיות (opt-in, כבויות כברירת-מחדל):

- **אבולוציה ריבונית** — בכישלון `probe`, מבקר מסיק את חוק-ה-WAF החוסם ומודל-האקר מסנתז עקיפה פולימורפית; "preflight" בצללים" מדמה תגובות-קצה לפני כל פעולה חיה.

- **C2 ריבוני** — מסובב honeytokens ורמזי-קפיצת-פורט חתומים לנכסי-הטעיה; יכול להעלות את רמת-ההגנה של ספק-הענן תחת התקפה (מאחורי דגלי אישור-כפול מפורשים).
 - **מפעל הפנטומים** — מייצר מפתחות-JWTs, SSH, ותצורות-API מזויפים כחומר-מלכודת.
 - **Nexus Sovereign Swarm** — נחיל היפר-סקיילי של עד ~10,000 סוכנים וירטואליים (ארכיטיפים: סייר, מנצל, מתאם, חמקני, אורקל) המגיעים לקונצנזוס רב-סוכני על ממצאים.
- כל אחת מאלה נשלטת על-ידי דגלי-סביבה שברירת-מחדלם **כבויה**, וכמה דורשות אישור-כפול מפורש כדי לבצע פעולות-ענן בעלות-השלכה.

8.6 מנועי חיזוי ואמולציה

- **חיזוי zero-day** — התאמה היוריסטית + טביעת-אצבע מול טבלה אצורה של רכיבים בסיכון-גבוה וצפיפות ה-CVE ההיסטורית שלהם.
- **תאום דיגיטלי** — בונה פרופיל-סביבה מכותרות חיות; תרחישי-סיכון מייעצים מסומנים בבירור וכבויים כברירת-מחדל.
- **אמולציית איומים** — מריץ שבעה תרחישי פרסונת-APT ומדווח אילו נחסמו.
- **מתכנן שרשראות-תקיפה דטרמיניסטי** — מתכנן בסגנון STRIPS הגוזר שרשראות-תקיפה **רק מעובדות שנצפו** (הוא אינו יכול להזות יכולות), המשלים את המתכנן הנרטיבי מבוסס-LLM.

9 תזמור ולולאת הפנטסט האוטונומית

מתזמר לכל-דייר מריץ מחזורי-סריקה מתמשכים (במרווח ניתן-לתצורה) וצינור קפדני בן חמישה שלבים:

שלב	שם	פעילות
0	מודיעין גלובלי	zero-day radar / סריקת מודיעין-איומים
1	גילוי עמוק	OSINT + מיפוי משטח-תקיפה, בתוספת חיזוי-נתיבים בסיוע-LLM
2	סריקת פגיעויות	מערך המנועים המלא, מצומצם למנועים-המאופשרים של כל לקוח
3	מהלומת-מחץ	סינתזת PoE — רק אם קיימת דריסת-רגל/ממצא (משוער)
4	ציוד	hash-שורש לביקורת + הפקת דוחות

המנועים לכל לקוח הם החיתוך בין `enabled_engines` של הלקוח ל-`active_engines` של הדייר. הקשר-גילוי משותף מזין רשימות-מילים ספציפיות-למחסנית (PHP/Django/Spring/Express וכו') ונתיבים שהתגלו בחזרה אל ה-fuzzers. **מצב-בטוח גלובלי** מרחיב את ה-jitter ומכניס השהיות בין-מנועים לחמקנות. כל הלולאה עטופה בבידוד-panic ומפסקי-זרם כך שמנוע בודד שמשלבש אינו יכול להפיל את המערכת.

סוכן הקצה ו-UEBA

10

בינארי Rust יחיד חוצה-פלטפורמות (`weissman-agent`, ~5MB) רץ על Linux, macOS ו-Windows כשירות. הוא נרשם מעל HTTPS לקבלת JWT לכל-סוכן, מתחזק **סשן WSS (WebSocket-מעל-TLS)** עם heartbeats וחיבור-מחדש בנסיגה-מעריכית, ואינו מחזיק מצב מקומי קבוע.

זיהויים ברמת-המארח (~20 יכולות מפורסמות על-פני 13 מודולי-מימוש) כוללים: זיהוי process-hollowing (היוריסטיקת נתיב-exe חסר), DLL-hijack / הרצה מתיקיה ברת-כתיבה, מצאי-תהליכים, מניית-מנגנוני-התמדה (cron / systemd / launchd / משימות-מתוזמנות), בדיקות ARP / MAC של שער ספופינג, היוריסטיקות אנומליית-DNS / ערוץ-סמוי, דגימת חילוץ-לוח (גודל + אנטרופיה), נוכחות EDR/AV (18 מוצרים ידועים), בדיקות שלמות-יומן, ומניית התקני-USB.

דוגם בייסליין UEBA (`baseline.rs` בסוכן, `ueba_detector.rs` בשרת): הסוכן דוגם תקופתית פורטים פתוחים, תהליכים מובילים, משתמשים ייחודיים, עומס/זיכרון, וכניסות-כושלות, מקובצים לפי **שעת-השבוע** (0-167). השרת מתחזק בייסליין מתגלגל בן 7 ימים לכל (סוכן, מדד, שעת-שבוע) ומפעיל **גלאי z-score**: $|z| > 3 \rightarrow$ בינוני, $|z| > 6 \rightarrow$ גבוה, בתוספת זיהוי קטגורי של פורטים/תהליכים שלא-נראו-מעולם — אך רק לאחר חלון-למידה קפדני (≤ 24 דגימות בדלי), כך שאינו מופעל בטרם-עת. דגימות נשמרות 14 ימים.

העובד האסינכרוני ומערכת המשימות

11

ה-`weissman-worker` הוא צרכן-משימות מבוזר עמיד:

- **שליפה-מתור** באמצעות `FOR UPDATE SKIP LOCKED` של PostgreSQL, נתמך באינדקס חלקי `(created_at, kind) WHERE status='pending'` שהפך שאילתה-חמה רב-שנייתית לסריקת-אינדקס של אלפיות-שנייה.
- **חכירה ו-heartbeats** — נעילה בת 300 שניות המוארכת כל 30 שניות; משימות תקועות נדרשות-מחדש.
- **נתיבי-מקביליות נפרדים** — סמפורים קלים (ברירת-מחדל 8) וכבדים (ברירת-מחדל 2); תפקיד-ברירה יכול להגביל עובד למשימות מחקר מול לקוח.
- **timeouts לכל-סוג** — מ-30 שניות (`ping`) ועד 60 דקות (`tenant_full_scan`), עם 27~ סוגי-משימות נבדלים (סריקות מלאות, דיבייטי-מועצה, deep fuzz, סינתזת PoE, auto-heal, ריצות מודיעין-איומים, סריקות-ענן, פריסות-הטעיה ועוד).
- **בידוד-panic ו-dead-lettering** — כל משימה רצה ב-task משלה עם ביטול-בעת-timeout וניסיון-חוזר בנסיגה-מעריכית למצב dead-letter.

אימות מחוץ-לתחום (OAST)

12

עבור מחלקות-פגיעות "עיוורות" (blind SSRF/XXE, JNDI, הזרקה מחוץ-לתחום), הפלטפורמה מריצה **שרת OAST עצמאי** (`weissman-oast-server`) המאזין גם ב-HTTP וגם ב-DNS, לוכד אינטראקציות הממופתחות ב-token ייחודי, ורושם כתובת-IP מקור, שיטה, נתיב, כותרות ופרטי-שאלתת-DNS למסד-הנתונים. המנועים מטמיעים tokens לכל-סריקה ב-payloads; ה-fuzzer לאחר מכן דוגם את המאזין כדי לאשר שקריאת-חזרה אמיתית התרחשה לפני סימון ממצא כמאומת. זהו ההבדל בין "שלחנו payload" לבין "הוכחנו שהיעד יצר איתנו קשר".

SOAR, פלייבוקים והתראות

13

פלייבוקי SOAR (`soar_playbook.rs`) משתמשים ב-DSL מבוסס-JSON:

```
when { severity, kev, epss_min, exposed, engines, cve_prefixes, cooldown_seconds }
do [ ...actions ]
```

שבעה סוגי-פעולה ממומשים: `open_pr`, `http_post`, `webhook`, `slack_notify`, `set_status` (מתור משימת-auto heal מאומתת), `isolate_host`, ו-`page_oncall`. השיגור הוא **אידמפוטנטי** (מפתח-dedup מבוסס SHA-256 עם חלון-cooldown) ונרשם במלואו ביומן. כל ממצא חדש שנשמר מוערך מול הפלייבוקים המאופשרים אוטומטית. **PlaybookBuilder** חזותי בממשק מספק בדיקת dry-run.

חוקי התראה הם מנגנון נפרד ופשוט יותר עם מעריך משלו (דוגם ממצאים אחרונים כל 60 שניות) וחמישה ערוצי-מסירה: `webhook`, `Slack`, `Microsoft Teams`, `PagerDuty`, ודוא"ל (SMTP) — עם deduplication של הפעלות לכל-ממצא.

הטעיה, בלימה וריפוי-עצמי

14

הטעיה / הגנה אקטיבית:

- **honeypot** המיוצרים דינמית (מפתחות AWS, אישורי-DB, מפתחות-API, נקודות-קצה צללים) ללא סודות מקודדים-קשוח.
- **canaries אמיתיים ב-AWS** — יוצר משתמש IAM עם מדיניות deny-all ומפתח-גישה, שותל ארטיפקטים מטעים ב-S3 / SSM / Parameter Store של הלקוח באמצעות assume-role חוצה-חשבונות, ומנטר דרך URL של OAST ו-webhook חתום של EventBridge; כל שימוש במפתח-ה-canary מעורר התראה.
- **blackholing של Cloudflare** — חסימה אופציונלית של ASN או 24 של תוקף בעת פגיעת-canary (מאחורי דגלי אישור-כפול).

בלימה (`cloud_containment_engine.rs`): הסגר EC2 (security group חדש לזיהוי-פלילי בלבד) ו-NetworkPolicy מסוג deny-by-default ב-Kubernetes.

ריפוי-עצמי: פעולת ה-SOAR `open_pr` מתור משימה המיישמת טלאי-מועמד, **מאמתת אותו בקונטיינר Docker ארעי** (הניצול עובד לפני, נכשל אחריו), ופותחת ענף + Pull Request ב-GitHub — תוך מחיקת ה-token של git לאחר השלמה.

שכבת הנתונים: PostgreSQL, ריבוי-דיירים ומיגרציות

15

- **PostgreSQL 16 + pgvector** (תוסף-הווקטור מפעיל את זיכרון-AI ואת חיזוק-הפנטסט). 88~ טבלאות-יישום על-פני סכמת-public מבוססת-דייר, סכמת `intel` גלובלית, ומראות EPSS/KEV; מוגדרות על-ידי **+74 מיגרציות SQL** (~4,000 שורות).
- **בידוד רב-דיירי באמצעות Row-Level Security**. לכל טבלת-דייר יש מדיניות `ENABLE` + `FORCE ROW LEVEL SECURITY` המופתחת ל-GUC מקומי-לטרנזקציה `app.current_tenant_id`. תפקיד-היישום כפוף ל-RLS; תפקיד-אימות נפרד עם `BYPASSRLS` מצומצם בקפדנות לבדיקות-כניסה ונרשם בעצמו ביומן (עם שלילה-אוטומטית בגישה חוצת-דיירים חשודה).

- **שלושה תפקידי מסד-נתונים:** `weissman_app` (כפוף-RLS), `weissman_auth` (כניסה בלבד), ו-`weissman_ro` (תפקיד הקריאה-בלבד לממשק השאילתות בשפה-טבעית, מוגבל ל-whitelist טבלאות הדוק עם timeout-פקודה ומגבלות-זיכרון משלו).
- **מריץ-מיגרציות דו-שלבי מותאם-אישית** (`no_tx_migrations.rs`) המזהה כותרת `-- weissman:no-transaction` ומריץ מיגרציות בסגנון `CREATE INDEX CONCURRENTLY` **מחוץ לכל טרנזקציה**, רושם אותן ב-`_sqlx_migrations` עם checksums תואמי-SQLx מסוג SHA-384 כך שהמריץ הסטנדרטי מדלג עליהן בבטחה. תלויות נדחות מיושמות-מחדש לאחר שטבלאותיהן קיימות. (זוהי בעיה קשה אמיתית שנפתרה בנקיון.)

שרת ה-API, אימות, RBAC והקשחה

16

ה-API (`weissman-server`, Axum על 8000:) חושף ~100 רישומי-ניתוב / ~130 נקודות-קצה שיטה-נתיב (ממומשות על-פני ~271 פונקציות-handler) בתוספת שישה ערוצי WebSocket, עם מפרט OpenAPI 3.1 ו-Swagger UI.

אימות (שכבתי):

- **אסימוני-גישה JWT** (HS256, TTL, ברירת-מחדל 15 דקות, עם `jwt` חובה לצורך שלילה), הנמסרים דרך עוגיית `HttpOnly` `Secure` או `Authorization: Bearer`.
- **אסימוני-רענון** הנשמרים רק כ-hashes של SHA-256, מסובבים בעת-שימוש, עם עוגיית `Strict` `SameSite` המצומצמת ל-`/api/auth`.
- **TOTP MFA** (הגדרה/הפעלה/אימות/השבתה), עם אכיפה ברמת-הדייר המחזירה `403 mfa_enrollment_required` כשהמדיניות דורשת.
- **SSO** דרך **OIDC** (`PKCE + nonce`), הקצאת-משתמש (JIT) ו-**SAML** (פרודקשן דורש אימות-חתימה של `xmlsec1`).
- **שלילת-אסימונים** – גם גישה (`denylist` של `jwt`) וגם רענון, עם אימות-RBAC חי-מחדש בכל בקשה מאומתת.
- **RBAC** – מודל מדורג בן שש דרגות: `viewer < analyst < operator < admin < ceo`, בתוספת דגל `superadmin` העוקף בדיקות-תפקיד, וזהות `agent` נפרדת. ההרשאה נאכפת בחמש שכבות: שומר-האימות, middleware של `mutation-RBAC` (כתיבות בלבד), middleware ייעודי ל-~63, CEO, בדיקות-מפורשות לכל-handler, ולבסוף RLS של PostgreSQL. גם התחום נאכף: יעד-סריקה חייב להיפתר לדומיין/IP מאושר עבור הלקוח, אחרת הוא נדחה ב-`403`, עם חסימת IPs פרטיים/שמורים והצמדת המארח/IP שנפתרו ואימותם-מחדש בזמן-הביצוע.

הקשחה (חלק ניכר ממנה נאכף באתחול – השרת מסרב לעלות בפרודקשן אם מופר):

- מערך כותרות-אבטחה מלא (HSTS, CSP, נוקשה, `X-Frame-Options: DENY`, `nosniff`, `Referrer-Policy`, `Permissions-Policy`).
- מדיניות TLS המסרבת ל-TLS לא-מאובטח בפרודקשן ומכריחה עוגיות `Secure`.
- שומרי-אתחול הדוחים סודות-JWT חלשים/ברירת-מחדל, סיסמאות-admin ברירת-מחדל, דילוג-אימות SAML לא-מאובטח, סיסמאות-DB ברירת-מחדל, אסימוני-metrics חסרים, ו(אלא אם single-node מאופשר במפורש) Redis חסר.
- **ארבע דרגות של הגבלת-קצב** (edge-לפי-API, IP-לפי-API, כניסה/הרשמה, וסריקה-לפי-דייר), נתמכות-Redis כשזמין; נעילת-חשבון לאחר 10 כשלונות.
- **השוואות בזמן-קבוע** (`subtle`) לאישור פעולה-הרסנית ואימות webhook.
- הגנת SSRF על בקשות יוצאות, רישום-ביקורת append-only, מגיני-panic עם מפסקי-זרם לכל-תווית, וניקויי שימור-נתונים ניתנים-לתצורה.

תצפיתיות, זמינות גבוהה וגיבויים

17

- **מדדי Prometheus** ב- `/api/metrics` (מוגן-token): היסטוגרמות וספירות השהיית HTTP, מדי בריכת-DB, מדי משימות-ממתנות ומחזורי-סריקה-פעילים, ומוני הצלחה/כשל גיבוי.
- **OpenTelemetry / OTLP** למעקב מבוזר עם לוגים מובנים אופציונליים ב-JSON; מזהה-מעקב מועבר מבקשות HTTP אל המשימות האסינכרוניות.
- **אפיק טלמטריית SSE** עם פיזור חוצה-רפליקות דרך Redis pub/sub המפעיל את מרכז-הפיקוד החי.
- **בחירת-מנהיג** דרך נעילה-מייעצת של PostgreSQL מבטיחה שיחידים (סריקות-המתזמר, גיבויים, מתזמנים, רענון-מודיעין) ירוצו בדיוק על צומת אחד — נכשלת סגור בפרודקשן.
- **גיבויי pg_dump** אוטומטיים עם gzip, מדיניות-שימור, וחוחות-זמן-הצלחה המיוצאות ל-Prometheus, משוערים לצומת-המנהיג.

מרכז הפיקוד (ממשק הווב)

18

- יישום עמוד-יחיד ב-Vite / React 18 בן ~69 עמודים עם נתיב נטענים-בעצלות (lazy-loaded), בינאום (i18next), וויזואליזציות-נתונים עשירות (recharts, גלובוס three.js, גרפים מ-@xyflow/react, TanStack Table, framer-motion).
- הדגשים:
- **Cockpit** עם רצועת-KPI מנהלית דביקה בסגנון "בלומברג" (ציון-אבטחה, ממצאים פתוחים לפי חומרה עם דלתות 24 שעות, MTTR, ספירות-נכסים, תור-משימות, סטטוס צי-הסוכנים) המתרעננת כל 15 שניות, בתוספת הזנת-פעילות חיה מעל-Server Sent Events.
 - **מפת מודיעין תלת-ממדית** (גלובוס מוזן-WebSocket עם קשתות-איום, radar, kill-chain) וחדר-מלחמה קולנועי.
 - משטחים תפעוליים: **FindingsCommandCenter** (טבלה ניתנת-לסינון + מגירה + ייצוא CSV), **RiskGraphVisualization** (גרף נתיב-תקיפה אינטראקטיבי), **AskWeissman**, **PlaybookBuilder**, **ThreatHuntingWorkbench**, **KillChainOrchestrator**, **RemediationHub** (צ'אט NL → SQL), **AgentManagement**, **ComplianceFrameworks**, **CloudControlTower**, **SupplyChainHub**, **OT/ICS**, **MobileSecurity**, **PQC Radar** ועוד.
 - **מרכז-פיקוד למנכ"ל** עם חדר-המלחמה של Genesis, מרתף-החיסונים, מעבדה-ריבונית, מטריצת-מנועי god-mode, וזרמי-מועצה חיים — מאחורי נתיב מוגן ייעודי וה-middleware של RBAC ל-CEO.

פריסה ותשתית

19

מספר נתיב-פריסה מהשורה הראשונה, כולם מאותם ארטיפקטים:

- **Docker Compose** — שער nginx (המגיש את ה-SPA, את אתר-השייוק, ומתווך `/api` + `/ws`), ה-frontend, העובד, PostgreSQL (pgvector), Redis; עם פרופיל-ניטור אופציונלי (Prometheus + Grafana + Alertmanager).
- **Kubernetes** (`deploy/k8s/`) — backend (2 רפליקות עם health probes), עובד, שער nginx (2 רפליקות), Redis, ingress, `weissmancyber.com`, PostgreSQL; configmap מונח כמנוהל/חיצוני.

- **systemd** (`deploy/systemd/`) — `weissman.target` הרוצה את יחידות השרת והעובד, עם עוזר-התקנה; הממשק בנוי לתוך התיקיה-הסטטית של הבינארי (אין Node.js בפרודקשן).
 - **Nix / NixOS** (`flake.nix` , `nix/nixos-modules/`) — בנייה רפרודוקטיבית (Crane + Fenix) עם פרופיל ייעודי `release-nix` ומודולים ל-bot, שירות vLLM וכונן HPC.
- פרופיל הגרסה של Rust מכוון לפרודקשן (LTO שמן, יחידת-codegen בודדת, סמלים מקולפים), ו-runtimes מודע-NUMA יכול להצמיד threads של סריקה ב-Linux.

איכות הנדסית ושערי CI/CD

20

- ה-CI (`.github/workflows/`) אורך רף-איכות רציני בכל שינוי:
- **Rust:** `cargo fmt --check` , Clippy , `-D correctness -D suspicious` , עם אזהרות (pedantic), `cargo test --workspace` , `cargo audit` (פגיעויות-תלויות).
 - **סנכרון מיגרציות:** סקריפט מבטיח ששתי תיקיות-המיגרציות נשארות זהות.
 - **סריקת-אבטחה:** gitleaks (סודות), Trivy (מערכת-קבצים + תמונות-קונטיינר), `npm audit` , Semgrep (SAST, דיווח-בלבד), ו-CodeQL (JS/TS + Python, שבועי).
 - **Python:** `pip-audit` + `ruff` + `pytest` . מותנה.
 - **Frontend:** ESLint, Vitest , ובניית-פרודקשן.
 - **חיווט-מנועים + smoke:** שער `verify_engine_wiring.mjs` (מנועים בממשק חייבים נתיב-ביצוע אמיתי), בניית-Docker של כל תמונה, שרת+עובד חיים שמועלים מול PostgreSQL + Redis אמיתיים, **בדיקת בידוד RLS חוצה-דיירים**, ובדיקות-smoke לקבוצות-מנועים.
- קרייט ה-Rust **אוסר קוד unsafe** באופן גורף, עם חריג מתועד אחד (הצמדת CPU מודעת-NUMA) הנושא אינוריאנטות-בטיחות מפורשות — עמדת בטיחות-זיכרון חזקה וברת-ביקורת.

השכבה המסחרית: חיוב, קליטה וציות

21

- **קליטה בשירות-עצמי** דרך שני נתיבים: הרשמה עם אימות-דוא"ל (יוצרת דייר + admin + מנוי-starter) ורישום B2B מידי — שניהם טרנזקציוניים, שניהם מאחורי דגלי-פרודקשן.
- **חיוב דרך Paddle** (הוסב מ-Stripe): תוכניות (starter / professional / enterprise) עם מכסות לקוחות וסריקות-חודשיות, טבלאות-מנוי ומוני-שימוש, webhooks חתומים, ואכיפה בגבולות יצירת-לקוח ושיגור-סריקה.
- **ציות** — מיפוי ממצאים חיים לבקורות **SOC 2, ISO 27001, ו-GDPR**, עם אחוזי-עמדה, סטטוס לכל-בקרה, ומסמכי-ביקורת PDF להורדה.
- **דיווח:** מסמכי PDF ארגוניים ללקוח (כריכה, מד-סיכון, גרפים, מפת-דרכים לתיקון, פירוט טכני, חותם קריפטוגרפי + QR), מסמכי PDF מנהליים לדרג-דירקטוריון עם אחוזי-ציות, ודוחות Markdown בסגנון bug-bounty.

עמדת בטיחות וממשל

22

מכיוון שהפלטפורמה מבצעת פעולות התקפיות, הבטיחות מהונדסת כעניין מהשורה הראשונה, לא כמחשבה שלאחר-מעשה. כל הבקורות להלן ממומשות:

1. **אכיפת-תחום** — כל יעד חייב להיות בתחום מאושר; מחוץ-לתחום → 403; IPs פרטיים/metadata חסומים; התחום מאומת-מחדש בזמן-הביצוע.
2. **אנושי-בלולאה** — פלט-מועצה מנושק דורש אישור-מפעיל מפורש; תצוגות-מקדימות של payload עוברות חיטוי (מילות-מפתח של shell מושחרות); משימות מאושרות רצות עם מסילת-בטיחות "ללא shells" שאינה ניתנת-למשא-ומתן.
3. **אמת-לפני-לימוד** — אסטרטגיות AI נכתבות לזיכרון רק לאחר אישור מחוץ-לתחום.
4. **בטיחות SQL → NL** — תכנית מ-SQL, allow-list, פרמטרי, תפקיד לקריאה-בלבד, אכיפת-תחום כפויה, timeout-פקודה.
5. **אוטונומיה כבויה-כברירת-מחדל** — כל הלולאות ה"ריבוניות" מושבתות אלא אם מאופשרות במפורש; פעולות-ענן בעלות-השלכה דורשות אישור-כפול; קיימים מתג-השבתה גלובלי ומצב-בטוח.
6. **ברת-ביקורת** — כל פעולה מאומתת, כל שלב-מועצה (חתום-HMAC), וכל שאילתת שפה-טבעית (עם ה-SQL המהודר) נרשמים ביומן.
7. **בידוד-דיירים** — נאכף במסד-הנתונים באמצעות RLS כפוי, נבדק ב-CI.
8. **בטיחות-זיכרון** — Rust עם `unsafe` אסור; בידוד-panic ומפסקי-זרם מונעים כשלים מתפשטים.
9. **מכסת-AI** — סריקות עתירות-AI מוגבלות-בקצב לכל-דייר.
10. **הוכחה, לא הצהרה** — ממצאים דורשים probes חיים; PoCs דורשים אימות-OAST/sandbox; תיקונים דורשים אימות Docker לפני/אחרי.

מחסנית הטכנולוגיה

23

שכבה	טכנולוגיות
שירותי-ליבה	Tokio, Axum, Tower/Tower-HTTP, SQLx אסינכרוני Rust (edition 2021, toolchain 1.91.1), runtime
מסד-נתונים	Redis, PostgreSQL 16 + pgvector (אינדקסי-וקטור HNSW)
AI/LLM	צ'אט + embeddings תואמי- (OpenAI (vLLM, Ollama, OpenAI; זיכרון-וקטור בן 1536 ממדים
קריפטו	OpenSSL, bcrypt, JWT (HS256), AES-256-GCM, HMAC-SHA256/384, ML-KEM (post-quantum), Ed25519
SDKs של ענן	AWS SDK (IAM, STS, S3, EC2, SSM), Cloudflare API, Kubernetes API
Frontend	React 18, Vite, react-router, recharts, three.js, @xyflow/react, framer-motion, i18next, TanStack Table
תצפיתיות	Prometheus (metrics-exporter), OpenTelemetry/OTLP, מעקב מובנה
אריזה / פריסה	Docker, Docker Compose, Kubernetes, systemd, Nix/NixOS
CI/CD	GitHub Actions, Clippy, cargo-audit, gitleaks, Trivy, Semgrep, CodeQL, ESLint, Vitest, Playwright
כלים מדור-קודם	Python (הזנות-מודיעין, כלי-קורלציה; הוחלפו ב-Rust לכלל ביצוע-פרודקשן)

היקף הנדסי (במספרים)

24

ממד	ערך
סך קוד-מקור מקורי	~193,000 שורות
מקור Rust (<code>.rs</code>)	~99,700 שורות
קבצי handler ניתוב Rust (<code>.inc</code>)	~17,800 שורות
מודולי Rust בקרייט-המנועים	239 קבצים
Frontend (React/JSX)	~54,500 שורות, 69 עמודים
מיגרציות SQL	75 קבצים, 4,076 שורות, <code>CREATE TABLE</code> 88
Python מדור-קודם	~17,000 שורות
קרייטי Workspace	9 קרייטי Rust
קטלוג מנועים	+500 מזהי-מנועים (~529 ברישום-הממשק) → 303 מנועים קנוניים
משטח-API	~130 נקודות-קצה, 271 handlers, <code>WebSocket</code> ערוצי
מסד-נתונים	~88 טבלאות, אבטחת רמת-שורה מלאה, 3 תפקידי-DB מצומצמים
סוגי-משימות אסינכרוניות	~27
זיהוי-סוכן	~20 יכולות על-פני 13 מודולים + בייסליין UEBA
הזנות מודיעין-אימים	4 (KEV, EPSS, NVD, OSV/GitHub)
מסגרות-ציות	3 (SOC 2, ISO 27001, GDPR)
בטיחות-זיכרון	<code>unsafe</code> אסור בכל הקרייט (חריג מתועד אחד)

סטטוס כן והערות מפת-דרכים

25

- ברוח מסמך מדויק ומבוסס-קוד, הניואנסים הבאים מנוסחים בבירור (והם דווקא משקפים לטובה את משמעת הצוות):
- ספירת המנועים מוצגת בכנות בקוד עצמו.** המוצר חושף +500 מזהי-מנועים, אך בסיס-הקוד מבחין בין ~303 מימושים קנוניים לבין כינויים אנכיים/שיווקיים באמצעות מודול-חשבונאות מפורש — שער CI מונע ממנוע בממשק להיוותר ללא נתיב-ביצוע אמיתי. הפלטפורמה נמנעת במכוון ממנועי “no-op” מנופחים.
 - זיהוי-הסוכן פרגמטיים.** מבין ~20 יכולות-הסוכן המפורסמות, אחדות הן כינויים מעל קוד-בדיקת-מארח משותף, והמדדים העשירים ביותר של UEBA הם `linux-first` (מערכות-הפעלה אחרות מתדרדרות בחן). זיהוי אחד (`timestomp`) קיים כ-`stub` ועדיין

אינו מחווט.

- **האוטונומיה מסופקת בטוחה-כברירת-מחדל.** היכולות ה"ריבוניות" החזקות ביותר מושבתות אלא אם מאופשרות במפורש, ופעולות-הענן בעלות-ההשלכה דורשות אישור-כפול. זוהי בחירת-בטיחות מכוונת, לא יכולת חסרה.
- **הפלטפורמה היא כתיבה-מחדש ב-Rust של מערכת Python מוקדמת יותר.** שכבת Python מדור-קודם נותרת בריפו לצורך הזנות-מודיעין וכלי-קורלציה, אך **כל ביצוע-הפרודקשן – API, תזמור, מנועים, עובד – הוא Rust.** סכמת ה-Alembic הישנה מסומנת במפורש כמיושנת לטובת מיגרציות ה-SQLx.
- **דאשבורדי-הניטור מדביקים את שמות-המדדים ששוננו.** חוקי-ההתראה של Prometheus עוקבים אחר שמות-המדדים הנוכחיים; דאשבורד Grafana עדיין מתייחס לכמה שמות מדור-קודם – פריט-יישור קוסמטי.

נספח א' — קטלוג המנועים המלא (303 מנועים קנוניים)

א'

הרישום המלא והמסודר של מימושי-המנועים הקנוניים (`FULL_ENGINE_REGISTRY_ORDER`) ב-
`backend/weissman-core/src/models/engine.rs` , מקובץ לפי תחום. אלה בנוסף ל-226 כינויים אנכיים/קטלוגיים
 שמתמפים למימושים אלה, ליצירת +500 המזהים המוצגים במוצר.

Recon, OSINT ומודיעין משטח-תקיפה: `recon` , `discovery_engine` , `leak_hunter` , `asm` , `osint` ,
`metadata_harvest` , `blockchain_trace` , `financial_osint` , `darkweb_intel` , `satellite_recon` ,
`github_secret_scan` , `job_posting_osint` , `iot_shodan_scan` , `telecom_osint` , `patent_recon` ,
`attack_surface_quantify` , `threat_intel_fusion` , `passive_dns_forensics` , `dark_web_monitor` ,
`adversarial_simulation`

התקפות Web ו-API: `http_smuggling` , `oauth_oidc` , `jwt_attack` , `graphql_attack` , `bola_idor` ,
`file_upload` , `ssti` , `xxe` , `ssrf_advanced` , `prototype_pollution` , `liminal_boundary` ,
`grpc_reflection_attack` , `graphql_deep_attack` , `cache_poisoning` , `websocket_attack` ,
`css_injection` , `odata_injection` , `soap_injection` , `swagger_abuse` , `http2_attack` ,
`web_cache_poison_adv` , `api_mass_assignment` , `http_parameter_pollution` , `template_injection_adv` ,
`deserialization_net` , `file_inclusion_rfi` , `subdomain_takeover` , `clickjacking_engine` ,
`idor_advanced` , `api_rate_limit_bypass` , `jwt_advanced_attack` , `nosql_deep_injection` ,
`api_gateway_bypass` , `web3_dapp_attack` , `webrtc_attack` , `graphql_subscription_attack`

אבטחת LLM / AI: `llm_redteam` , `ai_adversarial_redteam` , `semantic_ai_fuzz` , `llm_path_fuzz` ,
`prompt_injection_chain` , `nexus_sovereign_swarm` , `autonomous_pentest` , `adversarial_ml` ,
`adversarial_examples` , `rag_poisoning_engine` , `ai_supply_chain_attack` , `model_inversion_attack` ,
`gpt_plugin_attack` , `llm_dos_attack` , `deepfake_synthesis` , `data_poisoning_engine` ,
`neural_backdoor_detect` , `llm_memory_extraction` , `autonomous_ai_escape` ,
`model_stealing_engine` , `llm_red_team_advanced` , `federated_learning_attack` ,
`quantum_sovereign_nexus`

אבטחת ענן וקונטיינרים: `iac_misconfig` , `k8s_container` , `gcp_attack` , `azure_attack` , `aws_attack` ,
`lambda_escape` , `s3_bucket_attack` , `cloud_metadata_ssrf` , `serverless_attack` ,
`gcp_privilege_attack` , `azure_devops_attack` , `kubernetes_rbac_escape` , `cloud_iam_escalation` ,
`cloud_audit_evasion` , `service_mesh_attack` , `cloudformation_injection` , `terraform_state_attack` ,
`cloud_data_exfil` , `serverless_injection` , `cloud_worm_propagation` , `ecr_registry_attack` ,
`cloud_privilege_persistence` , `secrets_manager_attack` , `cloud_network_attack` , `eks_attack`

OT / ICS / IoT: `coap_attack` , `mqtt_attack` , `modbus_attack` , `ble_rf` , `iot_firmware` , `scada_ics` ,
`voltage_glitch_attack` , `lorawan_attack` , `plc_logic_bomb` , `modbus_exploit` , `opcua_attack` ,
`hmi_attack` , `plc_logic_attack` , `hospital_hl7_attack` , `cold_boot_attack` , `tpm_firmware_attack` ,
`rfid_nfc_attack` , `profinet_attack` , `firmware_emulation_attack` , `satellite_comm_attack` ,
`can_bus_surface` , `industrial_protocol_fuzz`

התחמקות, חמקנות ו-Malware: `antiforensics` , `timing_sidechannel` , `waf_bypass` , `edr_evasion` ,
`rootkit_simulation` , `sandbox_evasion` , `dll_hijacking_engine` , `stealth_engine`

, steganography_c2 , dns_tunneling_c2 , av_bypass_engine , memory_forensics_evasion , timing_evasion_engine , rop_chain_engine , icmp_covert , https_c2_masquerade , anti_debug_evasion , network_traffic_masking , com_hijacking , jit_spray , log_tampering_engine , polymorphic_engine , fileless_malware_engine , bootkit_uefi , parent_pid_spoof , worm_propagation , spyware_stalkerware , keylogger_engine , botnet_c2_engine , data_staging_engine , lateral_movement_engine , persistence_mechanism , rce_exploit_engine , macro_malware , trojan_dropper , exploit_kit_engine

, saml_attack , kerberoasting , password_spray , pqc_scanner , pki_tls : **קריפטוגרפיה וזהות:** , ecdsa_nonce_bias , hash_extension_attack , padding_oracle_attack , crypto_engine , pki_hierarchy_attack , kerberos_attack_suite , mfa_bypass_engine , rsa_timing_attack , saml_advanced_attack , oauth_advanced_attack , password_hash_crack , session_fixation_adv , password_spray_advanced , quantum_key_attack

, arp_spoofing_engine , smb_netbios , mtls_grpc , ipv6_attack , bgp_dns_hijacking : **רשת ופרוטוקול:** , dns_rebinding , dns_cache_poisoning , dhcp_attack_engine , vlan_hopping_attack , ss7_attack_simulation , ldap_injection_engine , rdp_attack_engine , snmp_exploitation , mpls_vpn_attack , ospf_bgp_hijack , bluetooth_attack_engine , wifi_attack_engine , wpa3_attack_engine , network_covert_channel , ipv6_advanced_attack , lte_5g_attack , network_tap_advanced , packet_injection_engine , protocol_downgrade , tor_exit_attack , network_baseline_anomaly , nat_traversal_attack , multicast_attack

, sbom_analyzer , container_registry , cicd_pipeline , supply_chain : **שרשרת-אספקה ו-CI/CD:** , github_actions_attack , pypi_supply_chain , npm_package_attack , typosquatting_monitor , cdn_poisoning_engine , compiler_backdoor , maven_supply_chain , docker_image_poison , sbom_forgery_engine , update_hijacking , build_system_compromise , software_signing_attack , iac_supply_chain , third_party_api_attack

, apt41_techniques , apt29_techniques , apt28_techniques : **אמולציית APT / שחקני-איום:** , salt_typhoon_ttps , scattered_spider_ttps , volt_typhoon_ttps , lazarus_group_ttps , cl0p_techniques , lockbit_techniques , conti_ransomware_ttps , fin7_techniques , equation_group_ttps , earth_longzhi_ttps , midnight_blizzard_ttps , blackcat_alphv_ttps , unc3944_ttps , unc2452_ttps , wizard_spider_ttps , carbon_spider_ttps , sandworm_techniques

, spear_phishing_engine : **הנדסה-חברתית (ניתוח-משטח בלבד — לא נשלחים payloads חיים של פישיוג):** , deepfake_voice_engine , qr_phishing , smishing_engine , vishing_engine , insider_threat_engine , pretexting_engine , watering_hole_attack , business_email_compromise , callback_phishing , linkedin_phishing , fake_update_engine , brand_impersonation , typosquatting_phishing , physical_social_eng

, ssl_pinning_bypass , mobile_mitm , ios_exploit_engine , android_malware_engine : **אבטחת מובייל:** , sim_swap_engine , mobile_overlay_attack , ios_url_scheme_attack , android_intent_attack , bluetooth_mobile_attack , mdm_bypass_engine , app_store_attack , mobile_banking_trojan , react_native_attack , mobile_spyware_engine , nfc_relay_attack

, cloud_exfil_engine , http_covert_exfil , dns_exfil_engine : **חילוץ-נתונים וערוצים-סמויים:** , cache_timing_exfil , optical_exfil , em_exfil_engine , acoustic_exfil , encrypted_exfil

, email_exfil , database_exfil , clipboard_hijack , screen_capture_exfil , keyboard_acoustic
storage_covert_channel , insider_exfil
, digital_twin , deception_honeypot , oast_oob , kill_chain :**(Top-Tier) הטעיה וחיזוי אימות**
poe_synthesis , threat_emulation , zero_day_prediction

מנועים שטכניקותיהם ברמת-המארח (הזרקת-תהליכים, USB, ARP, רדיו Wi-Fi/Bluetooth, חילוץ אקוסטי/אלקטרומגנטי/אופטי, התקפות פיזיות/אפיק וכו') מבוצעים על-ידי סוכן-הקצה או מסומנים בבירור **agent_required** / **info** כשאין אות מרחוק – לעולם לא מדווחים כפגיעויות-מרחוק מאומתות.

נספח ב' — מצאי טבלאות מסד-הנתונים המלא (88 טבלאות)

ב'

כל 88 טבלאות-היישום המוגדרות במיגרציות ה-SQL, מקובצות לפי פונקציה.

- **דיירות ולקוחות:** `pending_signups`, `engagements`, `system_configs`, `clients`, `tenants`
- **משתמשים ואימות:** `weissman_revoked_tokens`, `user_refresh_tokens`, `tenant_ids`, `users`, `security_events`
- **ממצאים ואינטליגנציית-זיהוי:** `weissman_finding_clusters`, `report_runs`, `vulnerabilities`, `weissman_correlation_incidents`, `findingSuppressions`, `engine_confidence_adjustments`
- **גרף-סיכון ומשטח-תקיפה:** `asm_graph_edges`, `asm_graph_nodes`, `risk_graph_edges`, `risk_graph_nodes`, `attack_chain`, `attack_path_snapshots`, `ot_ics_fingerprints`, `k8s_assets`, `aws_assets`
- **מודיעין-איומים:** `dynamic_payloads`, `threat_ingest_events`, `epss_intel`, `kev_intel`, `ephemeral_payloads`
- **משימות אסינכרוניות וצינור:** `poe_jobs`, `pipeline_run_state`, `weissman_async_jobs`
- **סוכני-קצה ו-UEBA:** `endpoint_agent_tasks`, `endpoint_agent_enrollment_tokens`, `endpoint_agents`, `agent_metric_baselines`, `agent_metric_samples`, `endpoint_agent_enroll_attempts`, `agent_anomalies`
- **SOAR, התראות, בלימה וריפוי-עצמי:** `weissman_playbook_runs`, `weissman_playbooks`, `soc_incident_playbook_steps`, `weissman_alert_rule_fires`, `weissman_alert_rules`, `heal_verification_steps`, `heal_requests`, `auto_heal_job_specs`, `containment_rules`
- **מועצת-AI, ריבוני-CEO:** `council_hitl_queue`, `supreme_council_rag_hits`, `supreme_council_memory`, `genesis_vaccine_vault`, `sovereign_learning_buffer`, `pentest_winning_paths`, `swarm_events`, `ceo_hpc_policy`, `ceo_war_room_events`, `genesis_suspended_graphs`, `edge_swarm_nodes`
- **הטעיה / הגנה אקטיבית:** `deception_cloud_deployments`, `deception_triggers`, `deception_assets`
- **טלמטריית fuzzing:** `llm_fuzz_events`, `semantic_fuzz_log`, `generative_fuzz_winning_payloads`
- **אנליטיקת-זהות:** `privilege_escalation_events`, `identity_contexts`
- **ציוד, ראיות והתקשרויות:** `roe_override_requests`, `evidence_items`, `compliance_mappings`, `cicd_scan_events`, `cloud_scan_findings`, `client_sbom_components`
- **סיכון פיננסי:** `client_financial_risk_snapshots`, `client_asset_value_rules`
- **חיוב:** `tenant_stripe_customers`, `tenant_usage_counters`, `tenant_subscriptions`, `billing_plans`, `stripe_webhook_events`
- **תזמון:** `weissman_scan_schedules`
- **ביקורת ותצפיתיות:** `runtime_traces`, `tenant_llm_usage`, `nl_query_audit`, `audit_logs`
- **אימות מחוץ-לתחום:** `oast_probe_tokens`, `oast_interaction_hits`

כל טבלת-דייר לעיל מוגנת ב-Row-Level Security כפוי של PostgreSQL. מראות-המודיעין הגלובליות (`kev_intel`), (`epss_intel`), תור-העובד חוצה-הדיירים (`weissman_async_jobs`), וטבלאות ה-payload בסכמת `intel` מוחרגות במכוון.

נספח ג' — מצאי נקודות-הקצה (API) המלא

ג'

כל רישומי-הניתוב בשכבת ה-HTTP (`fingerprint_engine/src/http/serve.rs`), מקובצים לפי פונקציה. רוב הנתונים תומכים במספר שיטות-HTTP (GET/POST/PATCH/DELETE).

- **אימות וסשן:** `/api/login` , `/api/logout` , `/api/auth/me` , `/api/auth/refresh` , `/api/auth/sse-ticket` , `/api/auth/signup` , `/api/auth/verify` , `/api/auth/mfa/setup` , `/api/auth/mfa/status` , `/api/auth/mfa/disable` , `/api/auth/mfa/verify` , `/api/auth/mfa/enable` , `/api/auth/saml/begin` , `/api/auth/saml/acs` , `/api/auth/oidc/begin`
- **קליטה וחיוב:** `/api/onboarding/register` , `/api/onboarding/target` , `/api/billing/usage` , `/api/billing/sync-paddle` , `/api/webhooks/paddle`
- **לקוחות ותחום:** `/api/clients/:id/report/pdf` , `/api/clients/:id/findings` , `/api/clients/:id/auto-heal` , `/api/clients/:id/deception` , `/api/clients/:id/export/csv` , `/api/clients/:id/llm-fuzz/run` , `/api/clients/:id/swarm/run` , `/api/clients/:id/sbom/export` , `/api/clients/:id/llm-fuzz/events`
- **ממצאים ומודיעין-זיהוי:** `/api/findings` , `/api/findings/clusters` , `/api/findings/export/csv` , `/api/export/findings` , `/api/intel/status` , `/api/intel/suppressions`
- **סריקות, משימות וצינור:** `/api/scan/status` , `/api/scan/stop` , `/api/scan/start` , `/api/scan/all-engines` , `/api/command-center/scan` , `/api/scan/run-all` , `/api/pipeline-scan/run` , `/api/command-center/ticker` , `/api/command-center/deep-fuzz` , `/api/poe-scan/stream/:job_id` , `/api/poe-scan/status/:job_id` , `/api/poe-scan/run` , `/api/scans/schedules/:id/run` , `/api/jobs/:job_id` , `/api/jobs` , `/api/timing-scan/run`
- **מנועים ו-fuzzing:** `/api/engines/accounting` , `/api/engines/production` , `/api/template-engine/run` , `/api/engines/export/:engine_id` , `/api/engines/history/:engine_id` , `/api/dag` , `/api/attack-coverage` , `/api/fuzz/ast-preview`
- **סיכון, אנליטיקה ודוחות:** `/api/dashboard/exec-kpis` , `/api/dashboard/stats` , `/api/risk/graph` , `/api/search` , `/api/reports/executive` , `/api/reports` , `/api/metrics/dashboard` , `/api/latency-probe`
- **תפעול SOC:** `/api/soc/kill-chains` , `/api/soc/iocs` , `/api/soc/hunts` , `/api/soc/incidents` , `/api/soc/network-protocols` , `/api/soc/exploit-lab` , `/api/soc/ai-patterns`
- **מועצת AI ומטה-כללי:** `/api/council/hitl/propose` , `/api/council/debate` , `/api/ask` , `/api/general/mission` , `/api/ai-redteam/run` , `/api/council/hitl/queue` , `/api/general/self-audit` , `/api/general/ascension`
- **מרכז-פיקוד המנכ"ל:** `/api/ceo/war-room/stream` , `/api/ceo/jobs/live` , `/api/ceo/telemetry` , `/api/ceo/vault/:id` , `/api/ceo/suspended-graphs` , `/api/ceo/vault/:id/match` , `/api/ceo/suspended-graphs/:id`
- **סוכני-קצה:** `/api/agents/dispatch` , `/api/agents/status` , `/api/agents/enroll` , `/api/edge-fuzz/manifest` , `/api/edge-swarm/nodes` , `/api/edge-swarm/heartbeat`

- **UEBA ובייטליין:** , /api/baseline/summary , /api/ueba/anomalies , /api/ueba/ingest
/api/baseline/anomalies , /api/baseline/drift
- **הטעיה ו-OAST:** , /api/deception/aws-events , /api/deception/triggered
/api/oast/callbacks , /api/oast/verify/:token , /api/oast/probe , /api/v1/alerts/aws-canary
- **מודיעין-אימים:** /api/threat-ingest/run , /api/threat-intel/run , /api/threat-intel/feed
- **משטחים ספציפיים-לתחום:** , /api/sbom/export , /api/sbom/components , /api/discovery/domains
/api/identity/contexts , /api/mobile-security/apps , /api/ot-ics/devices
/api/payload-sync/status , /api/payload-sync/run , /api/payload-sync/payloads
- **פלייבוקים ותיקון:** , /api/integrations/:id , /api/playbooks/:id/runs , /api/playbooks/fire
/api/heal-verify/:job_id/steps , /api/alerts/rules/:id/test , /api/integrations/:id/test
- **ציות וקריפטו:** , /api/crypto/pqc-selftest , /api/crypto/capabilities , /api/compliance/posture
/api/verify-audit/:hash
- **ראיות:** /api/evidence/:id/download , /api/evidence/:id
- **פלטפורמה ותפעול:** , /api/telemetry/stream , /api/audit-logs , /api/config/public , /api/health
/api/docs/ , /api/docs , /api/openapi.json , /api/system/backup
- **WebSockets (6):** , /ws/ai-redteam , /ws/timing , /ws/agent , /ws/command-center
/ws/swarm , /ws/threat-intel
- **Webhooks ומתקנים לא-מאומתים:** /hooks/cicd/bitbucket , /hooks/cicd/gitlab , /hooks/cicd/github
/install/agent.ps1 , /install/agent.sh , /hooks/cicd/scan ,
- **סטטי /SPA:** / , /dashboard , /*path (מרכז-הפיקוד React)

נספח ד' — מצאי עמודי מרכז-הפיקוד המלא

ד'

כל 68 העמודים המנותבים במרכז-הפיקוד React (/frontend/src/pages/):

, AskWeissman , AlertRulesEngine , AIAAnalysisEngine , AgentManagement , AdminManagement
 , BusinessEngineProfile , Billing , BaselineAndDrift , AuditLog , AstFuzzingStudio
 , ClientEvidenceVault , ClientEngagements , ClientDetail , CeoVault , CeoCommandCenter
 , ComplianceFrameworks , CloudControlTower , Clients , ClientSaasIdpDiscovery , ClientNew
 , DigitalTwinSimulator , DarkWebMonitor , CouncilHitlQueue , ContainmentRulesBuilder
 , EngineMatrix , EngineManagementConsole , EngineDetail , EngineClientCatalog , DomainDiscovery
 , IdentityContextManager , FindingsCommandCenter , FeedbackLoopVerification , ExploitResearchLab
 , KillChainOrchestrator , JobsDashboard , IntegrationManager , IncidentResponseCenter
 , NetworkProtocols , NetworkIntelligence , MobileSecurity , MetricsDashboard
 , OtIcsSecurity , OsintEngineProfile , OobVerification , OastDashboard , NexusSovereignSwarm
 , RiskGraphVisualization , RemediationHub , RateLimitAnalytics , PqcRadar , PlaybookBuilder
 , StatusPage , SsoDashboard , SocialEngineering , ScanScheduler , SBOMBrowser , RoeApprovals
 , TemplateEngineWorkbench , SystemConfiguration , SupplyChainHub , StrategicEngineProgram
 , ThreatIntelHub , ThreatHuntingWorkbench , ThreatEmulation , ThreatAnalysisCenter
 , VulnIntelDashboard , TopTierEngineProfile , TopTierEngineHub

(בתוספת רכיבים משותפים: 29~ רכיבי 7 cockpit ויזואליזציות 10 war-room, רכיבי CEO-בלבד, וספריית רכיבי-UI בסיסיים.)

מסמך זה הופק על-ידי ניתוח ישיר של קוד-המקור. כל טענה לעיל ניתנת למעקב עד למודול, מיגרציה או handler ספציפי בריפוזיטורי, והמערכת מתוכננת כך שטענתה החשובה ביותר — שהמצאים אמיתיים ושפלט ה-AI מאומת — נאכפת על-ידי הקוד ולא מוצהרת על-ידי התיעוד.